

ĐẠI HỌC QUỐC GIA TP.HCM

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN



**ĐỒ ÁN MÔN HỌC
AN TOÀN MẠNG**

SƠ ĐỒ CẤU TRÚC MẠNG CHI TIẾT

BLUE TEAM

Giảng viên hướng dẫn – TS. Lê Kim Hùng

Sinh viên thực hiện:

23520552 – Phan Cảnh Đăng Huân
23520479 – Lê Đình Hiếu

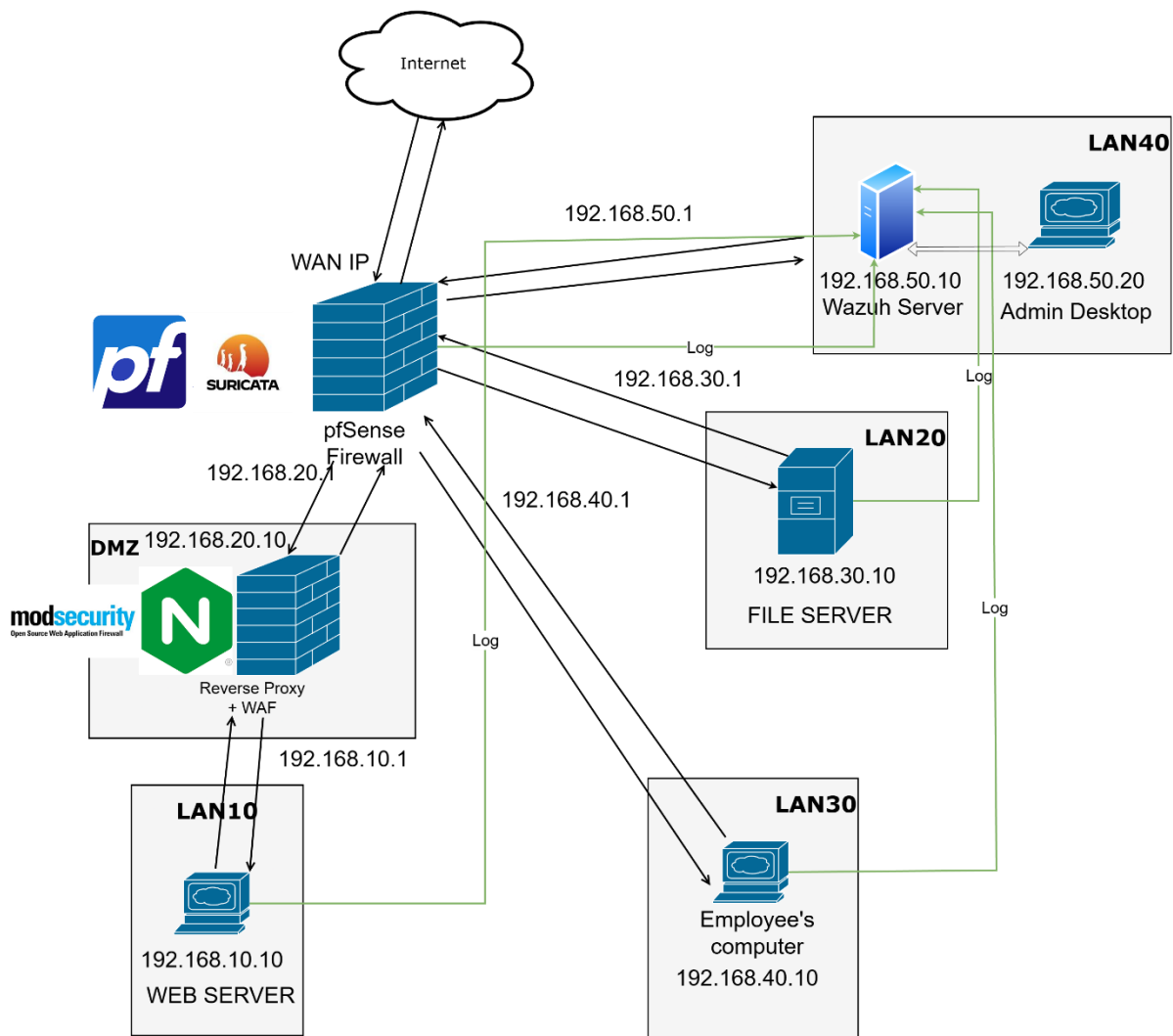
Mục lục

1. TỔNG QUAN KIẾN TRÚC.....	3
2. CHI TIẾT CÁC VÙNG MẠNG	4
WAN (Untrusted Zone)	4
DMZ (192.168.20.0/24).....	4
LAN10 (192.168.10.0/24).....	4
LAN20 (192.168.30.0/24).....	4
LAN30 (192.168.40.0/24).....	5
LAN40 (192.168.50.0/24).....	5
3. LUỒNG DỮ LIỆU.....	5
Luồng truy cập Web	5
Luồng dữ liệu nội bộ	5
Luồng quản trị và giám sát	5

1. TỔNG QUAN KIẾN TRÚC

Hệ thống mạng được thiết kế tuân thủ mô hình phòng thủ theo chiều sâu (Defense-in-Depth) và nguyên tắc phân đoạn mạng (Network Segmentation). Hệ thống được chia thành 5 vùng mạng riêng biệt, được kiểm soát bởi pfSense Firewall nhằm đảm bảo các mục đích:

- **Cô lập:** Đảm bảo các tài sản quan trọng được tách biệt khỏi các vùng có rủi ro cao.
- **Kiểm soát luồng:** Mọi kết nối giữa các vùng đều phải được kiểm tra bởi pfSense Firewall và Suricata (IDS/IPS).
- **Hạn chế lây lan:** Ngăn chặn tuyệt đối các hành vi Lateral Movement nếu một vùng mạng bị xâm nhập.



2. CHI TIẾT CÁC VÙNG MẠNG

Vùng mạng	Subnet	Thành phần	Chiến lược
WAN	DHCP cấp	Internet Access	Áp dụng luật Default Deny và chặn các dải IP không hợp.
DMZ	192.168.20.0/24	Reverse Proxy (Nginx + ModSecurity WAF)	Lớp bảo vệ đầu tiên của hệ thống. Nhiệm vụ lọc các request trước khi chuyển đến Web Server.
LAN10	192.168.10.0/24	Web Server (chạy trên Docker)	Máy chủ chạy Docker được Hardening.
LAN20	192.168.30.0/24	File Server (Samba)	Cho phép Server truy cập vào, nhưng nghiêm cấm mọi kết nối ra Internet để chống thất thoát dữ liệu.
LAN30	192.168.40.0/24	Employee PCs	Bị chặn kết nối đến các vùng mạng khác (ngoài LAN20)
LAN40	192.168.50.0/24	Wazuh SIEM Server, Admin Desktop	Máy Admin bị chặn truy cập Internet, chỉ được phép kết nối đến các Server để quản trị (SSH/RDP) và chỉ Wazuh được phép ra ngoài để cập nhật luật.

Chi tiết như sau:

WAN (Untrusted Zone)

WAN là vùng kết nối trực tiếp với Internet. Đóng vai trò là cửa ngõ giao tiếp, nơi kết nối của mọi lưu lượng truy cập (cả hợp lệ và tấn công) từ bên ngoài.

DMZ (192.168.20.0/24)

Tại đây có máy chủ Reverse Proxy tích hợp WAF (ModSecurity). Máy chủ tại đây không chứa dữ liệu quan trọng, chỉ có nhiệm vụ tiếp nhận yêu cầu, lọc mã độc và chuyển tiếp yêu cầu sạch vào bên trong. Nếu Attacker tấn công thành công vùng này, họ vẫn bị cô lập và không thể truy cập trực tiếp vào dữ liệu bên trong.

LAN10 (192.168.10.0/24)

Tại đây đặt Web Server (Nginx) và ứng dụng được build bằng Docker. Vùng này bị cô lập hoàn toàn với Internet. Web Server chỉ nhận kết nối từ DMZ Proxy. Mọi kết nối trực tiếp từ Internet vào LAN10 đều bị chặn.

LAN20 (192.168.30.0/24)

Đây là nơi đặt File Server đang chạy Samba. Chính sách bảo mật ở đây là nghiêm ngặt nhất để tránh rò rỉ và thất thoát dữ liệu.

LAN30 (192.168.40.0/24)

Đây là vùng mạng chứa máy tính của nhân viên. LAN30 là vùng có độ tin cậy thấp do người dùng dễ bị tấn công. Do đó, vùng này bị cấm truy cập sang các vùng khác (LAN10, LAN40) để ngăn chặn các cuộc tấn công Lateral Movement.

LAN40 (192.168.50.0/24)

Đây là vùng quản trị của cả hệ thống, bao gồm Wazuh SIEM Server và Admin Desktop. Đây là nơi duy nhất được phép SSH/RDP vào các Server khác để bảo trì. Máy Admin Desktop tại đây được cách ly khỏi Internet để tránh rủi ro bị nhiễm mã độc.

3. LUỒNG DỮ LIỆU

Luồng dữ liệu trong hệ thống được định tuyến và kiểm soát theo quy tắc quyền tối thiểu.

Luồng truy cập Web

Yêu cầu từ Internet phải đi qua DMZ (để WAF kiểm tra) trước, sau đó mới được Reverse Proxy chuyển tiếp đến Web Server (LAN10). Không cho phép luồng truy cập trực tiếp từ WAN vào LAN10/LAN20/LAN40.

Luồng dữ liệu nội bộ

File Server (LAN20) không thể kết nối đến bất kỳ vùng nào khác (ngoại trừ Wazuh Agent gửi log). Điều này đảm bảo dữ liệu quan trọng không thể bị lấy ra ngoài. Samba được mã hóa (SMB Encryption) để đảm bảo tính bảo mật khi truyền tải file trong nội bộ.

Luồng quản trị và giám sát

Admin Desktop (LAN40) có thể kết nối đến tất cả các Server (thông qua SSH/RDP). Và mọi Server có trong hệ thống đều phải gửi log về Wazuh để giám sát.